

SaaS & Tecnología

Adecuación operativa al nuevo marco de protección de datos personales

El rol del encargado de tratamiento: DPA, seguridad de plataforma, IA y gestión de brechas.

01·12·2026 Vigencia plena Régimen sancionatorio operativo	20.000 UTM Multa gravísima ~\$1.400 millones aprox.	+50% Recargo Si no subsana en 60 días
--	--	--

Datos clave del nuevo régimen

■ Vigencia plena 1 de diciembre de 2026
■ Notificación de brechas <i>Sin dilaciones indebidas</i> a la Agencia y a los afectados
■ Delegado de Protección de Datos (DPO) Generalmente voluntario (Art. 50); obligatorio por excepción legal
■ Reincidencia (grandes empresas) Hasta 2%–4% de los ingresos brutos anuales
■ Recargo por no subsanar 50% adicional si no corrige en 60 días

Resumen ejecutivo

Lo esencial en 30 segundos

Las empresas SaaS/cloud actúan como encargados de tratamiento: prohibido usar datos de clientes para fines propios o cederlos. El DPA es obligatorio y debe incluir confidencialidad, límites de uso, seguridad y retorno/destrucción al término del servicio. Shadow AI: el 97% de las compañías vulneradas por incidentes con IA carecía de políticas formales de acceso a modelos. Los LLMs en producción son sub-encargados: deben declararse en el RAT y recibir datos sanitizados de PII. Transferencias internacionales: solo hacia países adecuados o con Cláusulas Contractuales Tipo chilenas / BCRs registrados.

1. El rol del encargado de tratamiento y el contrato DPA

Las empresas SaaS, de software o de servicios cloud actúan fundamentalmente como encargados del tratamiento (Artículo 15 bis) cuando procesan bases de datos personales por cuenta de sus clientes corporativos (los responsables del tratamiento). La ley chilena prohíbe que el encargado destine esos datos personales a fines comerciales propios o los ceda a terceros sin autorización expresa del responsable original. Es obligatorio celebrar un Contrato de Encargo de Tratamiento o Data Processing Agreement (DPA) que incorpore taxativamente los requisitos de confidencialidad, seguridad, límites de uso y retorno/destrucción segura de la información al término del servicio.

2. Gobernanza ante el riesgo crítico de "Shadow AI"

El uso no autorizado de herramientas de IA generativa (como ChatGPT, Gemini o Copilot) por parte de colaboradores internos, alimentándolas con bases de datos de clientes, planillas de RR.HH. o contratos confidenciales, representará un vector crítico de fuga de datos bajo la Ley 21.719. El 97% de las compañías vulneradas por incidentes asociados a IA carecía de políticas formales de acceso a modelos corporativos. El costo promedio de una brecha de seguridad vinculada a IA asciende a US\$670.000, según reportes globales del sector. Las empresas tecnológicas deben estructurar políticas claras de gobernanza de inteligencia artificial, bloqueando el uso de herramientas públicas que utilicen los datos de prompts para reentrenar sus modelos.

3. Saneamiento de datos de entrenamiento e IA en producción

Si los sistemas digitales de la empresa SaaS incorporan inteligencia artificial en producción para automatizar interacciones o reportes, se debe garantizar la soberanía de los datos: Declarar explícitamente el uso de motores de IA o LLMs secundarios como sub-encargados de tratamiento en el RAT. Implementar procesos automáticos de anonimización irreversible o sanitización de PII antes de enviar datos personales a APIs externas de inteligencia artificial.

4. Transferencias internacionales de datos y cláusulas modelo

La ley regula de forma estricta el flujo transfronterizo de datos personales (por ejemplo, bases de datos de usuarios chilenos almacenadas en la nube en servidores de AWS, Azure o GCP en Estados Unidos). La transferencia internacional es lícita únicamente si se realiza hacia países con nivel adecuado de protección o si cuenta con garantías adecuadas, como la firma de las Cláusulas Contractuales Tipo (CCT) aprobadas por la ley chilena o Normas Corporativas Vinculantes (BCRs) previamente registradas en la APDP.

Casos típicos del sector

Situación	Gravedad probable
Un ingeniero pega un acuerdo confidencial de cliente en un chatbot público para resumirlo.	Grave
El producto envía consultas de usuarios a una API de IA externa que no figura ni en el RAT ni en el DPA del cliente.	Grave
Al vencer el contrato, el cliente solicita devolución y borrado total, incluyendo respaldos.	Grave

Régimen sancionatorio

Categoría	Sanción máxima	Ejemplos típicos
Leve	5.000 UTM	Incumplir plazos, no entregar información clara
Grave	10.000 UTM	Tratar datos sin base legal, vulnerar seguridad
Gravísima	20.000 UTM	Uso fraudulento, filtración intencional de datos sensibles

Infraacción	Techo en UTM	Equivalencia aprox.*
Leve	5.000 UTM	~ \$345 millones
Grave	10.000 UTM	~ \$690 millones
Gravísima	20.000 UTM	~ \$1.400 millones

*Valores referenciales con UTM de agosto 2026 (~\$69.000). El valor de la UTM se reajusta mensualmente según IPC.

■ Vigencia plena

1 de diciembre de 2026

■ Notificación de brechas

Sin dilaciones indebidas a la Agencia y a los afectados

■ Delegado de Protección de Datos (DPO)

Generalmente voluntario (Art. 50); obligatorio por excepción legal

■ Reincidencia (grandes empresas)

Hasta 2%–4% de los ingresos brutos anuales

■ Recargo por no subsanar

50% adicional si no corrige en 60 días

Checklist de implementación sectorial

1. Implementar una política interna de gobernanza de IA para controlar "Shadow AI".
2. Garantizar que las consultas a LLMs en producción estén sanitizadas de datos personales

Hoja de ruta sugerida de implementación

Días 1–30 · Diagnóstico

Inventario RAT, mapa de flujos de datos y brecha frente a la ley.

Días 31–60 · Adecuación

Políticas actualizadas, contratos DPA, canales ARSOP y banners de consentimiento.

Días 61–90 · Cultura y pruebas

Capacitación, simulacro de brecha, revisión final y designación DPO si corresponde.

Preguntas frecuentes

¿Somos responsables o encargados?

Si procesas datos solo según instrucciones del cliente, eres encargado; si decides fines y medios propios, también eres responsable.

¿Puedo seguir hospedando datos chilenos en EE.UU.?

Sí, mediante garantías adecuadas: cláusulas contractuales tipo chilenas o normas corporativas vinculantes registradas ante la APDP.

¿Sanitizar los prompts antes de enviar a la IA basta?

Es la base mínima: además declara el sub-encargo en RAT/DPA y verifica contractualmente que el proveedor no reentrena con tus datos.

¿Necesitamos DPO siendo SaaS B2B?

Depende del volumen y naturaleza: el procesamiento masivo por cuenta de terceros justifica designarlo como sello de cumplimiento ante clientes corporativos.

¿Qué pasa si un empleado filtra datos vía IA y hay brecha?

Aplica el protocolo de brechas: contención, notificación a la APDP (sin dilaciones indebidas), aviso a los responsables afectados y remediación documentada. Levantar el RAT de todos los sub-encargados contractuales y plataformas cloud donde residan datos de clientes. Actualizar y estandarizar la plantilla de contrato de encargo (DPA) conforme al Artículo 15 bis.

Glosario esencial

Shadow AI

uso no autorizado de herramientas de IA generativa por colaboradores con datos sensibles o confidenciales.

Sub

encargado — tercero contratado por el encargado (ej. motor de IA cloud); requiere autorización y condiciones equivalentes.

Sanitización / PII

eliminación o anonimización irreversible de datos personales identificables antes de procesamiento externos.

CCT / BCR

cláusulas contractuales tipo chilenas y normas corporativas vinculantes: garantías válidas para transferencias internacionales.

Multi

tenancy — arquitectura compartida entre clientes; exige segregación lógica fuerte y borrado verificable por arrendatario.

ARSOP

Derechos de Acceso, Rectificación, Supresión, Oposición y Portabilidad que todo titular puede ejercer.

APDP

Agencia de Protección de Datos Personales: organismo fiscalizador del nuevo régimen.

RAT

Registro de Actividades de Tratamiento: inventario interno obligatorio de qué datos se tratan, para qué y con quién.

DPA

Data Processing Agreement o contrato de encargo de tratamiento entre responsable y encargado.

DPO

Delegado de Protección de Datos (Art. 50): figura generalmente voluntaria, obligatoria solo por excepción legal.

Brecha de seguridad

Pérdida, robo o acceso no autorizado a datos personales; debe notificarse sin dilaciones indebidas.

MPI

Modelo de Prevención de Infracciones: programa interno de cumplimiento que atenúa sanciones.

UTM

Unidad Tributaria Mensual, unidad monetaria indexada usada para calificar multas (reajustada por IPC).

Fuente oficial

Ley 21.719 — Biblioteca del Congreso Nacional de Chile (idNorma=1209272). Documento orientativo de trabajo; ante dudas específicas consultar siempre el texto vigente.